

Evidence Semantics and Scanner Orchestration

Salesforce Security Observatory

TABLE: Field | Value

Version | 1.1.0

Published | 1 August 2026

Created by | Luca Pacini

Published by | FortMilo

Source baseline | f834844b

Status | Source-established architecture; runtime and release validation incomplete

This paper does not claim that every scanner family has completed successfully in a current runtime execution, that the package is release-validated, or that every Salesforce edition is supported.

1. Evidence is not one value

Security tooling must separate four questions:

1. Did the assessment process execute?
2. Was the required source available?
3. What value did the source return?
4. What conclusion may safely be drawn?

A displayed zero can mean a successful query returned no records. It can also mean that a source was unavailable, unsupported, hidden by permissions, not configured, not selected, not retained, or that the scanner failed. Only the first condition supports a genuine empty-result statement.

Execution outcome, source availability, metric value and permitted interpretation are independent dimensions.

1.1 Abstract model and rendered states

The evidence model is analytical; it is not a second UI vocabulary.

TABLE: Abstract condition | Canonical product state

Available source, matching records | Value or finding with scope

Available source, no matching records | None found

Source or family not assessed | Not assessed

Detail excluded by evidence level | Not assessed at this evidence level

Evidence not retained | Not captured

Required source could not be read | Unavailable plus cause and next action

Feature genuinely does not apply | Not applicable

A scanner issue is the reason for a non-green canonical state, not a competing display value.

2. Scan and family granularity

Scan-level and scanner-family outcomes must not be mixed.

- Completed: orchestration reached finalisation; family limitations still apply.
- Completed with warnings: finalisation completed but one or more families were non-green.
- Failed: orchestration did not reach a valid terminal boundary.
- Not assessed: no valid assessment exists.

At family level:

- success with records renders a scoped value or finding;
- success with no records renders None found;
- a partial composite source renders a visible partial marker beside every count, drill-down and export;
- source or family failure renders a non-green state with a safe cause and next action.

A partial count must never look complete. If Source A returns three records while Source B is unavailable, the UI may show three only with an adjacent incomplete marker.

3. Evidence confidence and support

TABLE: Label | Meaning

Source-established | Visible in reviewed implementation source

Test-observed | Exercised by an automated test fixture

Runtime-observed | Occurred in a reviewed organisation execution

Release-validated | Passed the gates on the exact candidate

Expected | Architecture suggests the behaviour; validation is incomplete

Not assessed | No reliable conclusion is available

Architectural statements in this version are Source-established unless another basis is printed. Full-plan runtime completion is Not assessed for this publication. The paper therefore publishes neither a fixed Queueable transaction count nor an unqualified Developer Edition completion claim.

Current public support status:

- source-established: Salesforce-native controller, service, scanner plan, evidence persistence and subscriber-controlled self-callout pattern;
- expected with prerequisite: Tooling-backed evidence when the subscriber authorises the Named Credential and External Credential principal;
- not assessed: universal edition support, production-scale performance and complete release-candidate validation.

No unpublished compatibility matrix is referenced.

4. Salesforce-native architecture

Evidence basis: Source-established.

Authorised operator
 -> Lightning dashboard
 -> Apex controller and scan service
 -> Apex-owned scanner plan
 -> Salesforce record and setup sources
 -> subscriber-authenticated callout to the same org Tooling API
 -> sanitised Observatory-owned evidence
 -> dashboard, drill-down, comparison and CSV export

The security boundary is categorical: no scan evidence leaves the subscriber organisation. The self-callout is to the subscriber's own Salesforce Tooling API, not to an external evidence destination.

Scanners are read-only against Salesforce security configuration. The Observatory writes only its own evidence records. It does not revoke tokens, remove permissions, block API access, change endpoints or remediate findings.

5. Scanner orchestration

Evidence basis: Source-established. Runtime completion of the full current plan: Not assessed.

Apex owns the scanner plan so manual, scheduled and future API entry points cannot silently diverge. Work is divided by callout and non-callout needs.

The durable contract is:

- callout boundaries are explicit;
- compatible non-callout work may share a transaction;
- each segment receives a fresh governor-limit context;
- a segment enqueues at most one next segment;
- finalisation occurs only at the terminal boundary;
- an isolated family failure remains visible and may allow later independent work to continue;
- an orchestration failure stops unstarted work and fails the assessment boundary.

The fixed segment count is intentionally omitted because it is an implementation detail that must be re-verified after batching or ordering changes.

6. Safe causes and next actions

Every non-green state requires:

- a safe cause;
- the affected evidence boundary;
- a safe administrator next action.

The fail-closed unknown category is not a bare Unknown label. Its mandatory next action is to review scanner-family status and prerequisite guidance, understand the visibility or configuration issue, then rerun.

Raw exception messages, stack traces, SOQL, API responses and diagnostic-shaped values are not retained in dashboard evidence or exports.

7. Sanitisation and subscriber-controlled Tooling access

Retained evidence may include bounded counts, dates, safe names, categories, source identifiers required for review, sanitised findings, safe relationships, limitations and comparison state.

It excludes access and refresh tokens, session identifiers, passwords, client secrets, private keys, certificate bodies, authorisation headers, raw platform responses, raw stack traces, raw queries and raw IP values. The raw-IP statement is the retained/exported evidence contract; it is not a claim that Salesforce source objects never contain IP information.

Apex callout
 -> Named Credential
 -> External Credential
 -> subscriber-authorised principal
 -> same Salesforce organisation Tooling API

There are no packaged tokens or hard-coded secrets. Removing the authorised principal access is the practical revocation control. When the prerequisite is absent, Tooling-backed evidence degrades visibly rather than becoming zero.

8. Historical evidence and SBS

A retained scan belongs to a particular time, evidence level, visibility boundary and mapping context. Historical review must not requery current sources to fill old gaps, reinterpret older results with current configuration, treat omitted detail as resolved, compare incompatible evidence as like-for-like, or convert legacy unavailable states into zero.

Security Benchmark for Salesforce control references provide traceability, not certification. They do not establish control satisfaction or organisational compliance.

Attribution: Security Benchmark for Salesforce identifiers and documentation are attributed to the Security Benchmark for Salesforce project and its authors. SBS documentation is licensed under Creative Commons Attribution-ShareAlike 4.0 International. No endorsement or affiliation is implied.

9. Public wording

TABLE: Avoid | Use

No exposure exists | No matching exposure evidence was observed within the assessed sources
The scanner passed | The scanner family returned usable evidence
Clean | None found within the successfully assessed source and scope
The token is active | An authorisation record was retained, or point-in-time activity was observed, as stated
The control is compliant | The retained evidence supports review of the mapped control
All editions are supported | Edition support is not assessed in this publication
Proven in Developer Edition | Runtime completion is not claimed in this version
Platform limits are bypassed | The plan is segmented to operate within Salesforce transaction boundaries

10. FortMilo, source and licence

FortMilo is the public publication surface. Luca Pacini is the creator of this paper and the Salesforce Security Observatory project.

The source reviewed for version 1.1.0 is maintained in a private pre-release repository under the Apache License, Version 2.0. No public source-repository URL is claimed. A later version may add the exact URL when a sanitised public repository is released.

Copyright 2026 Luca Pacini. This paper is licensed under the Apache License, Version 2.0. Third-party trademarks and separately licensed SBS material are excluded.

11. Conclusion

A security dashboard is trustworthy only when it can explain the path from source to statement: what ran, what source was assessed, what it returned, what could not be assessed, what may be concluded, what limitation or next action remains, and what evidence basis supports the claim.

Nothing found and nothing assessed are not the same result.

References

1. Salesforce Secure Apex Classes: <https://developer.salesforce.com/docs/platform/lwc/guide/apex-security>
2. Salesforce Named Credentials: <https://developer.salesforce.com/docs/platform/named-credentials/guide/get-started.html>
3. Security Benchmark for Salesforce: <https://docs.securitybenchmark.org/>
4. CC BY-SA 4.0: <https://creativecommons.org/licenses/by-sa/4.0/>
5. Apache License 2.0: <https://www.apache.org/licenses/LICENSE-2.0>
6. FortMilo: <https://fortmilo.co.uk/>